



Microsoft Entra ID & Endpoint Estate

Engagement reference:

Tenant ID: 204d355e-3092-40a5-b516-b8c31be6717b

Report generated: 13 June 2026 07:31 UTC

Assessment method: Read-only Microsoft Graph collection

This report presents the results of a Zero Trust security assessment of the Microsoft Entra ID and endpoint estate of . The assessment was conducted using read-only collection against the Microsoft Graph and evaluated the tenant against a library of Zero Trust controls spanning identity, conditional access, privileged access, application security, devices, governance, and monitoring.

The estate currently sits at an , with a risk posture of . Maturity and risk are reported side by side and deliberately not blended: maturity describes how much of recommended practice is in place, while risk posture is capped at “At Risk” whenever any Critical exposure exists, regardless of the overall score. Four Critical and six High findings drive the current posture.

The most urgent exposures concern multi-factor authentication and privileged access. MFA is not universally enforced, administrators lack phishing-resistant authentication, and at least one application holds standing high-privilege permissions that bypass interactive sign-in entirely. Together these represent direct, unchallenged paths to tenant compromise and should be remediated first.

Encouragingly, application security (58.3%) and identity security (40%) are comparatively more mature, providing a foundation to build on. A three-wave remediation roadmap over 180 days is set out at the end of this report, sequenced to stop active exposure first and then build durable, sustainable control.

OVERALL MATURITY	MATURITY LEVEL	RISK POSTURE	CRITICAL / HIGH RISKS
------------------	----------------	--------------	-----------------------

The assessment was performed entirely through read-only Microsoft Graph collection. No changes were made to the tenant, and no write permissions were requested or used. Evidence was persisted to the engagement run folder so that findings can be re-examined offline and independently verified.

Configuration was assessed against the toolkit's Zero Trust check library and scored on two independent axes:

- — the proportion of recommended controls that are in place, expressed as a percentage and a named maturity level per domain and Zero Trust pillar.
- — a qualitative rating that reflects active exposure. The presence of any Critical finding caps the posture at “At Risk” irrespective of the maturity percentage.

Where data could not be collected — for example because a licence, permission, or workload was unavailable — the relevant domain is reported as **Insufficient data** rather than being scored or assumed compliant. Five device- and hybrid-related domains fall into this category and should be revisited once the corresponding telemetry is available.

The table below shows maturity for each assessed domain. Domains marked “Insufficient data” were not scored because the required configuration or telemetry could not be collected.

Domain	Score	Maturity Level	Visual Progress
ApplicationSecurity	80%	Managed	
IdentitySecurity	60%	Developing	
PrivilegedAccess	40%	Initial	
IdentityGovernance	20%	Basic	
ConditionalAccess	20%	Basic	
MonitoringDetection	10%	Initial	
ByodGovernance	Insufficient data	Insufficient data	
CorporateDeviceGovernance	Insufficient data	Insufficient data	
DeviceTrust	Insufficient data	Insufficient data	
EndpointManagement	Insufficient data	Insufficient data	
HybridIdentity	Insufficient data	Insufficient data	

Domain results roll up to the three core Zero Trust pillars. Two of the three pillars could not be fully scored in this run and are reported as Insufficient data; least-privilege scored 31.9% (“Basic”).

	—	InsufficientData
	31.9%	Basic
	—	InsufficientData

The findings below carry the highest business impact and should anchor the remediation plan. Critical findings represent direct, often unchallenged, paths to compromise; High findings materially weaken the control environment.

			An app permission such as RoleManagement.ReadWrite.Directory is a standing path to Global Administrator that no MFA ever challenges.
			Universal MFA enforcement is the single most effective identity control; report-only policies do not protect anyone.
			Administrator credentials are the highest-value target; they warrant stronger protection than the general user population.
			A single privileged account without MFA provides a direct path to tenant compromise; coverage for administrators must be absolute.
			This is the policy-side control underpinning ID-003; without it legacy protocols bypass every other Conditional Access control.
			Risk-based policies respond automatically to credential leaks and anomalous sign-ins, shrinking the attacker window without user friction.
			Device trust signals are central to Zero Trust; without device conditions, fully unmanaged endpoints access corporate data unchecked.
			Azure management access grants control over infrastructure; per-app targeting frequently misses it when policies are not all-apps.
			Unmanaged endpoints carry no compliance signal and no endpoint protection; a large unmanaged share means Conditional Access device controls protect only part of the estate.
			Accounts without MFA are the primary target of password spray and phishing attacks; Microsoft telemetry shows MFA blocks the overwhelming majority of identity attacks.

Acting on the following recommendations will close the four Critical findings and materially reduce the High-severity exposure:

- by moving report-only policies into enforcement; report-only mode protects no one (CA-001, ID-001, ID-002).

- — the highest-value accounts warrant stronger authentication than the general population (CA-002).
- such as RoleManagement.ReadWrite.Directory, which provide a path to Global Administrator that no MFA challenge ever sees (AS-002).
- , which otherwise bypasses every other Conditional Access control (CA-003).
- so access responds to credential leaks, anomalous sign-ins, and unmanaged endpoints, and ensure critical applications are protected by all-apps policies (CA-004, CA-005, CA-011, DT-001).

Thirty findings require remediation, sequenced into three delivery waves by severity and effort. Wave timings run from engagement acceptance and assume the customer’s change processes operate normally.

	0–30 days		Stop active exposure: enforce universal and phishing-resistant MFA, remove standing high-privilege app permissions, and block legacy authentication.
	30–90 days		Build durable control: risk-based Conditional Access, device-based access, protection of critical applications, and governance of privileged roles.
	90–180 days		Mature and sustain: close monitoring and detection gaps, extend device and BYOD governance, and operationalise continuous review.

- This report is and intended solely for the named recipient organisation.
- Findings reflect tenant configuration at the point of collection (13 June 2026 07:31 UTC) and may change as the environment is modified.
- All evidence was gathered through read-only Microsoft Graph collection; the assessment made no changes to the tenant.
- Findings marked “NotAssessed” or “Insufficient data” state the reason the relevant data was unavailable and are not assumptions of compliance.